

Deploying securely: StackSets, CloudFormation Guard, Service Catalog and RAM

How controls reach 200 accounts, how you stop a bad template, and how people build without holding the permissions.

Whatever deploys your infrastructure can deploy **anything**. Treat it as the most privileged thing you own.

Self-managed, or service-managed?

SELF-MANAGED PERMISSIONS

You create the roles

- Administration role in the admin account
- Execution role in every target account
- Works with accounts outside an organisation
- You maintain the roles yourself

SERVICE-MANAGED PERMISSIONS

CloudFormation creates them

- Requires Organizations trusted access
- Target the whole org, or specific OUs
- Automatic deployment to new accounts
- Cannot target accounts outside the org

THE TIEBREAKER

Automatic deployment is the security argument: an account created next Tuesday inherits your controls without anyone remembering.

Two StackSets facts worth knowing

- ◆ **CloudFormation does not deploy stacks to the management account**, even inside a targeted OU.
- ◆ So an org-wide control is **absent from the one account SCPs cannot constrain either** (module 32).
- ◆ **Delegated administrators can deploy to any account in the organisation.**
- ◆ **The management account cannot limit them by OU or operation.** AWS documents this plainly.
- ◆ Treat the StackSets delegated administrator as an organisation-wide privileged role.

ON THE EXAM

Two gaps that compound: the management account is exempt from SCPs and skipped by StackSets.

CloudFormation Guard

- ◆ Open-source **policy-as-code** with its own DSL. The CLI is **cfn-guard**.
- ◆ Validates **JSON and YAML generally** – CloudFormation, Kubernetes manifests, Terraform JSON plans.
- ◆ Runs at dev time, as a **pre-commit hook**, in GitHub Actions, CodePipeline or Jenkins.
- ◆ Two operations: **validate** resources against rules, and **test** that your rules behave as intended.
- ◆ In a pipeline it only sees what goes through the pipeline.

ON THE EXAM

A rule that never matches passes everything, silently. Hence 'test'.

Guard Hooks: the same rules at deployment time

- ◆ **Guard Hooks** enforce the same rules **inside CloudFormation at deployment time**.
- ◆ This is the **proactive control** mechanism from module 32 – evaluated before provisioning.
- ◆ Activated **per account and Region**, appearing as a **private Hook** in the registry.
- ◆ Deploy them everywhere with a **service-managed StackSet** – the two halves of this module.
- ◆ It evaluates **CloudFormation** operations. A CLI call still goes past.

ON THE EXAM

cfn-guard in a pipeline is advice. A Guard Hook is enforcement.

Service Catalog and the launch role

- ◆ Administrators publish **products** in **portfolios**; users launch without writing templates.
- ◆ **The launch constraint is the security feature.** Service Catalog assumes a **launch role**.
- ◆ An end user with only **read-only catalogue access** can launch an RDS product **holding no RDS permissions**.
- ◆ Without it, users need permissions on every underlying resource – defeating the point.
- ◆ Also **template, stack set, tag update** and **notification** constraints.

ON THE EXAM

The permission lives in the role, not in the person.

AWS Resource Access Manager

- ◆ Share across accounts **without copying** – subnets, Transit Gateways, Private CA, Resolver rules.
- ◆ Module 29's **logically air-gapped vaults**, including with **other organisations**.
- ◆ A **resource share** names resources, principals and a **managed permission**.
- ◆ Within an organisation needs **trusted access**; then no invitation is required.
- ◆ The **owning account keeps ownership and billing**.

ON THE EXAM

Shared VPC: one network account owns it, application accounts get subnets.

Secrets in templates

- ◆ **A NoEcho parameter is still stored.** It hides the value in the console and describe-stacks. The template is not encrypted.
- ◆ Use **dynamic references** – resolve from Secrets Manager or Parameter Store at deployment time.
- ◆ Better: have CloudFormation **create** the secret, so no human ever sees the value.
- ◆ Templates live in source control, copied and forked more widely than anyone plans.
- ◆ Module 17: **Q Developer secrets detection** catches this before commit.

ON THE EXAM

NoEcho is the closest thing in CloudFormation to security theatre.

A security team deploys its incident response role to every account with a service-managed StackSet targeting the organisation root, with automatic deployment enabled. An audit confirms the role exists in all 213 member accounts.

During a later incident affecting the management account, responders find the role is not there. The StackSet reports no failures and no drift.

Why is the role missing?

- ☐ A CloudFormation does not deploy stacks to the management account, even within a targeted OU
- ☐ B The StackSet must be re-run with automatic deployment disabled to include the management account
- ☐ C An SCP on the root is blocking role creation in the management account
- ☐ D Service-managed StackSets require the management account to be in a separate OU

◆ PAUSE AND DECIDE

Why is the role missing?

- A

 CloudFormation does not deploy to the management account
Correct. AWS documents it explicitly - the management account is skipped even when it belongs to a targeted OU, which is why no failure is reported.
- B

 Re-run without automatic deployment
Automatic deployment governs whether new accounts joining an OU get the stack. It has no bearing on the management account exclusion.
- C

 An SCP is blocking it
Module 32: SCPs have no effect in the management account. If an SCP were responsible, it could not be - and there would be a failure.
- D

 The management account needs its own OU
Placement does not change the exclusion. CloudFormation skips the management account wherever it sits.

THE SIGNAL

'No failures and no drift' is the tell. The account was never a target, so nothing failed - it was simply skipped.

A platform team must let 300 developers provision standardised RDS databases. Compliance requires that developers hold no RDS permissions of their own, so they cannot create a database outside the approved configuration or modify one afterwards. The team has an approved CloudFormation template that creates an encrypted, private, backed-up RDS instance.

What should the team implement?

- ☐ A Grant developers `rds:CreateDBInstance` with a condition requiring encryption and a private subnet
- ☐ B A service-managed StackSet deploying one database per developer account
- ☐ C A Service Catalog product with a launch constraint, so Service Catalog assumes a launch role
- ☐ D A CloudFormation Guard rule in the pipeline rejecting non-compliant RDS templates

◆ PAUSE AND DECIDE

What should the team implement?

- A

 Grant RDS permissions with conditions
Directly contradicts the requirement that developers hold no RDS permissions. Conditions narrow a grant; they do not remove it.
- C

 Service Catalog product with a launch constraint
Correct. The launch role holds the RDS permissions; developers hold only end-user access to the catalogue and cannot modify what was created.
- B

 A StackSet deploying one database each
StackSets push identical stacks on an administrator's schedule. Developers need self-service provisioning when they want it.
- D

 A Guard rule in the pipeline
Validates templates that go through the pipeline. It does not provision anything, and does not stop a developer with RDS permissions acting outside it.

THE SIGNAL

'Developers hold no RDS permissions' is the requirement. Only the launch role pattern separates the permission from the person.

A company runs cfn-guard in its CodePipeline, rejecting templates that create unencrypted resources. An audit finds several unencrypted EBS volumes created from CloudFormation stacks deployed directly from engineers' workstations, bypassing the pipeline entirely.

The company wants the same rules enforced regardless of how a stack is deployed, without blocking the pipeline path.

What should the company implement?

- ☐ A An SCP denying cloudformation:CreateStack except from the pipeline role
- ☐ B A Config rule detecting unencrypted volumes, with automatic remediation
- ☐ C Move cfn-guard into a pre-commit hook so engineers run it locally
- ☐ D Activate a Guard Hook in each account and Region, deployed by service-managed StackSet

◆ PAUSE AND DECIDE

What should the company implement?

- A

 SCP denying CreateStack except from the pipeline
Genuinely effective and broader than asked - it removes a legitimate workflow rather than validating it. Worth considering, and it is a different decision.
- B

 Config rule with remediation
Detective and corrective. The volume exists unencrypted until remediation runs, and EBS cannot be encrypted in place - it would need replacing.
- C

 cfn-guard as a pre-commit hook
Runs on the engineer's machine and can be skipped. A control the person being controlled can bypass is advice, not enforcement.
- D

 Guard Hooks in each account and Region
Correct. A Guard Hook enforces the same rules inside CloudFormation at deployment time, so every stack operation is evaluated regardless of origin.

THE SIGNAL

The rules were right and the enforcement point was wrong. Move enforcement to where the resource is actually created.

A security team registers a dedicated account as the StackSets delegated administrator so that deployments do not run from the management account. The team then asks how to restrict that delegated administrator to deploying only into the non-production OU.

The management account owner wants assurance that a compromise of the delegated administrator cannot reach production accounts.

What should the team be told?

- ☐ A Attach an SCP to the production OU denying the delegated administrator's role
- ☐ B Delegated administrators can deploy to any account in the organisation, and the management account cannot restrict them by OU
- ☐ C Set the StackSet's account filter to exclude production accounts, which enforces the restriction
- ☐ D Use self-managed permissions and create execution roles only in non-production accounts

◆ PAUSE AND DECIDE

What should the team be told?

A SCP on the production OU
Service-managed StackSet operations are performed by the management account, so an SCP on the production OU is not evaluating the delegated administrator's own principal.

C Account filters enforce the restriction
Account filters scope a particular StackSet's targets. Whoever holds delegated administration can create another StackSet with different filters.

B They can deploy anywhere, and cannot be restricted by OU
Correct. AWS documents this directly. The delegated administrator is an organisation-wide privileged role, and must be secured as one.

D Self-managed with execution roles only in non-production
Genuinely does bound the blast radius - and abandons service-managed permissions, losing automatic deployment to new accounts.

THE SIGNAL

The honest answer is that the restriction they want does not exist. The mitigation is to secure the role, not to scope it.

Six things to carry forward

- ◆ **CloudFormation does not deploy to the management account.** No failure is reported.
- ◆ **A StackSets delegated administrator can deploy anywhere,** unrestrictable by OU.
- ◆ **cfn-guard is advice.** A Guard Hook is enforcement.
- ◆ **A launch role holds the permissions so the user does not.**
- ◆ **RAM shares without copying;** the owner keeps ownership and billing.
- ◆ **NoEcho is presentation, not protection.** Use dynamic references.

ON THE EXAM

Next: SRA, Well-Architected and Trusted Advisor – closing Domain 6.